



CLASS GUIDELINE

DNV-CG-0325

Edition December 2024

Cyber secure

This copy of the document is intended for use by DNV employees only.

The content of this service document is the subject of intellectual property rights reserved by DNV AS ("DNV"). The user accepts that it is prohibited by anyone else but DNV and/or its licensees to offer and/or perform classification, certification and/or verification services, including the issuance of certificates and/or declarations of conformity, wholly or partly, on the basis of and/or pursuant to this document whether free of charge or chargeable, without DNV's prior written consent. DNV is not responsible for the consequences arising from any use of this document by others.

The PDF electronic version of this document available at the DNV website dnv.com is the official version. If there are any inconsistencies between the PDF version and any other available version, the PDF version shall prevail.

FOREWORD

DNV class guidelines contain methods, technical requirements, principles and acceptance criteria related to classed objects as referred to from the rules.

© DNV AS December 2024

Any comments may be sent by e-mail to rules@dnv.com

This service document has been prepared based on available knowledge, technology and/or information at the time of issuance of this document. The use of this document by other parties than DNV is at the user's sole risk. Unless otherwise stated in an applicable contract, or following from mandatory law, the liability of DNV AS, its parent companies and subsidiaries as well as their officers, directors and employees ("DNV") for proved loss or damage arising from or in connection with any act or omission of DNV, whether in contract or in tort (including negligence), shall be limited to direct losses and under any circumstance be limited to 300,000 USD.

CHANGES – CURRENT

This document supersedes the August 2021 edition of DNV-CG-0325.
The numbering and/or title of items containing changes is highlighted in red.

Changes December 2024

<i>Topic</i>	<i>Reference</i>	<i>Description</i>
General	All sections	Rewritten to cover guidance of IACS UR E26 Rev.1 and UR E27 Rev.1, as implemented in DNV-RU-SHIP Pt.6 Ch.5 Sec.21 edition July 2024.

Editorial corrections

In addition to the above stated changes, editorial corrections may have been made.

CONTENTS

Changes – current.....	3
Section 1 General.....	6
1 Introduction.....	6
2 Objective.....	6
3 Scope.....	6
4 Application.....	6
5 References.....	6
6 Definitions and abbreviations.....	7
Section 2 Class notation Cyber secure.....	10
1 Introduction.....	10
2 Defence in depth.....	10
3 Security profiles (SP).....	11
4 System under consideration (SuC).....	11
5 Class notation variants.....	12
6 Additional qualifier +.....	12
7 Overview of implementation and verification activities.....	13
Section 3 Compliance documents.....	16
1 Introduction.....	16
2 Compliance documents.....	16
3 Product certification.....	16
4 Requirements for product certificate.....	18
Section 4 Newbuilding projects.....	22
1 Introduction.....	22
2 Design phase.....	23
3 Construction phase.....	29
4 Acceptance phase.....	31
Section 5 Alteration projects.....	33
1 Introduction.....	33
2 Design phase.....	34
3 Modification phase.....	35
4 Acceptance phase.....	36
Section 6 Operation.....	37

1 Introduction.....	37
2 Guidelines for content of CSMS.....	37
Appendix A List of computer-based systems in the default SuC.....	43
1 Introduction.....	43
Changes – historic.....	49

SECTION 1 GENERAL

1 Introduction

Recognizing that maritime safety relies on cyber-physical systems that are increasingly integrated with networks and designed with commercial off-the-shelf (COTS) products, cyber security has become a concern which needs to be specifically addressed.

The class notation **Cyber secure** addresses cyber security by providing requirements and verification of technical barriers, processes, and people awareness based on management of cyber risks on board DNV classed vessels.

2 Objective

The objective of this document is to provide guidance to designers, system integrators, shipyards, product suppliers, shipowners, and operators about correct and efficient implementation of the class notation **Cyber secure**.

3 Scope

The scope of this document is to provide further, detailed information related to [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#) for the class notation **Cyber secure** and to [DNV-RU-SHIP Pt.8 Ch.2 Sec.2](#) for the in-operation class notation **CSMS**.

4 Application

This document is intended to be used in conjunction with [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#) and [DNV-RU-SHIP Pt.8 Ch.2 Sec.2](#) specifying the requirements for class notation **Cyber secure** and in-operation class notation **CSMS**, respectively.

5 References

[Table 1](#) lists DNV references used in this document.

Table 1 DNV documents

<i>Document code</i>	<i>Title</i>
DNV-CP-0231	Cyber security capabilities of systems and components
DNV-RP-0496	Cyber security resilience management for ships and mobile offshore units in operation
DNV-RU-SHIP Pt.1 Ch.2	Class notations
DNV-RU-SHIP Pt.4 Ch.9	Control and monitoring systems
DNV-RU-SHIP Pt.6 Ch.5 Sec.21	Cyber security
DNV-RU-SHIP Pt.7 Ch.4 Sec.5	Digital features
DNV-RU-SHIP Pt.7 Ch.5 Sec.2	Management services
DNV-RU-SHIP Pt.8 Ch.2 Sec.2	Cyber security management system - CSMS and Cyberman

Table 2 lists other references used in this document.

Table 2 Other references

<i>Document code</i>	<i>Title</i>
IACS UI SC134	Essential Services and Arrangements of Sources of Power, Supply, Control and Monitoring to the different Categories of Essential Services (SOLAS Regulations II-1/40 & 41) - June 2002
IACS UR E26	Cyber resilience of ships - Rev.1 Nov 2023
IACS UR E27	Cyber resilience of on-board systems and equipment - Rev.1 Sep 2023
IMO MSC-FAL.1/Circ.3	Guidelines on maritime cyber risk management
IMO Res. MSC.428(98)	Maritime cyber risk management in safety management systems
IEC 61162-460	Maritime navigation and radiocommunication equipment and systems - Digital interfaces - Part 460: Multiple talkers and multiple listeners - Ethernet interconnection - Safety and security
IEC TS 62443-1-1	Industrial communication networks - Network and system security - Part 1-1: Terminology, concepts and models
IEC 62443-2-1	Security for industrial automation and control systems - Part 2-1: Security program requirements for IACS asset owners
IEC 62443-3-2	Security for industrial automation and control systems - Part 3-2: Security risk assessment for system design
IEC 62443-3-3	Industrial communication networks - Network and system security - Part 3-3: System security requirements and security levels
IEC 62443-4-2	Security for industrial automation and control systems - Part 4-2: Technical security requirements for IACS components
ISM Code	International Safety Management Code
ISO/IEC 27001	Information security, cybersecurity and privacy protection - Information security management systems - Requirements
ISO/IEC 27035-1	Information technology - Information security incident management - Part 1: Principles and process
ISO/IEC 27035-2	Information technology - Information security incident management - Part 2: Guidelines to plan and prepare for incident response
NIST SP 800-37	Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy
SOLAS	International Convention for the Safety of Life at Sea

6 Definitions and abbreviations

6.1 Definition of verbal forms

The verbal forms defined in Table 3 are used in this document.

Table 3 Definition of verbal forms (normative)

<i>Term</i>	<i>Definition</i>
shall	verbal form used to indicate a requirement strictly to be followed
should	verbal form used to indicate that among several possibilities, one is recommended as particularly suitable, without mentioning or excluding others
may	verbal form used to indicate a course of action permissible within the limits of a requirement

6.2 Definition of terms

The terms defined in [Table 4](#) are used in this document.

Table 4 Definition of terms

<i>Term</i>	<i>Definition</i>
compensating countermeasure	countermeasure (e.g. security barrier) in lieu of a required security capability Provides an alternate and equivalent solution to the stated requirement. The compensating countermeasure shall reduce the cyber risk introduced by the missing required security capability.
compliance document	document confirming compliance with at least one standard, is identifying the target and is validated and signed by the issuing organization E.g. certificates and maker's declarations See also DNV-RU-GEN-0587 and DNV-CG-0550
computer-based system	see IACS UR E27: a programmable electronic device, or interoperable set of programmable electronic devices, organized to achieve one or more specified purposes such as collection, processing, maintenance, use, sharing, dissemination, or disposition of information
default SuC	consists of the computer-based systems and equipment needed for the mandatory functions specified in DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 9
information technology	application of computers to store, study, retrieve, transmit and manipulate data, or information, often in the context of a business or other enterprise
operational technology	hardware and software dedicated to detecting or causing changes in physical processes through direct monitoring and/or control of physical devices such as valves, pumps, etc.
system under consideration	SuC is a collective term for all computer-based systems and equipment to be considered in a project with class notation Cyber secure
systems integrator	company responsible for high-level design and integration of systems on board. This role is typically performed by the shipyard
supplier	for this CG it is primarily regarded as the company supplying cyber-physical systems and components that is part of the SuC

6.3 Abbreviations

The abbreviations described in [Table 5](#) are used in this document.

Table 5 Abbreviations

<i>Abbreviation</i>	<i>Description</i>
CBS	computer-based system
CSMS	cyber security management system
DoS	denial of service
DP	dynamic positioning
FAL	Convention on Facilitation of International Maritime Traffic
HAT	harbour acceptance test
IACS	International Association of Classification Societies
IEC	International Electrotechnical Commission
IMO	International Maritime Organization
ISA	International Society of Automation
ISO	International Organization for Standardization
IT	information technology
MSC	Maritime Safety Committee
OT	operational technology
PC	product certificate
SL	security level
SP	security profile
SR	security requirement
SuC	system under consideration
TAC	type approval certificate
TADC	type approval design certificate
USB	universal serial bus

SECTION 2 CLASS NOTATION CYBER SECURE

1 Introduction

There are three different variants of the class notation **Cyber secure** as illustrated in Figure 1. Each variant represents a level of cyber risk reduction (security profile) applied to the computer-based systems in scope of the class notation (system under consideration).

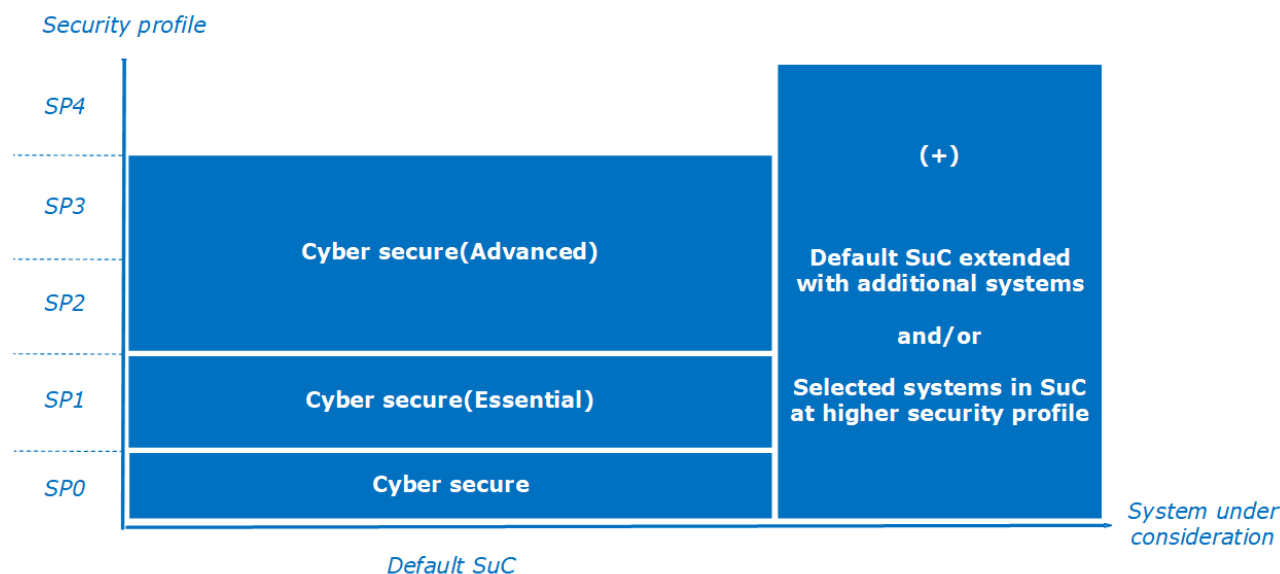


Figure 1 Variants of class notation Cyber secure

2 Defence in depth

The class notation constitutes a defence in depth strategy where cyber security risk reduction measures shall be implemented by multiple methods and layers as follows:

- 1) inherent security capabilities and controls in the software components of the computer-based systems
- 2) security zones and conduits, controlling logical access to networks and computer-based systems and preventing propagation of security incidents
- 3) physical risk reduction measures, controlling physical access to locations on board in accordance with policies for access control in the cyber security management system yber security management system (CSMS), addressing management activities, competence, and behaviour of people as per the in-operation class notation **CSMS**.

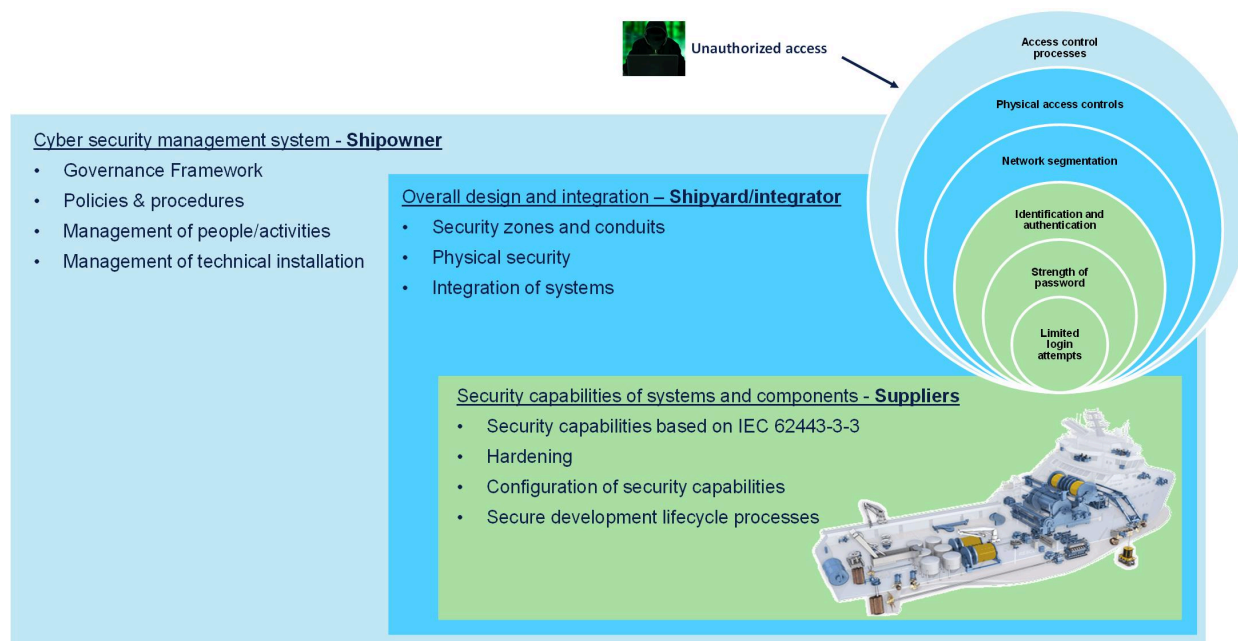


Figure 2 Example of defence in depth for unauthorized access

3 Security profiles (SP)

The security level (SL) concept is introduced in the IEC 62443 and specifies a given set of technical security controls to achieve different levels of cyber risk reduction.

Security profiles (SP) are intended for different industry/groups, sectors, or organizations to tailor the selection of requirements to their need. The Society has defined five incremental security profiles (SP0 to SP4) where the highest security profile represents the greatest risk reduction:

- Security profile 0 (SP0) represents an initial level of cyber risk reduction and includes security controls addressing the most prominent security threats.
- Security profile 1 (SP1) is based on IEC 62443 security level 1 and specifies security controls addressing intentional violation by threat actors in a casual or coincidental manner. This security profile is aligned with IACS UR E26 and UR E27.
- Security profile 2 (SP2) is based on IEC 62443 security level 2 and specifies security controls addressing intentional violation by threat actors possessing low resources and low motivation.
- Security profile 3 (SP3) is based on IEC 62443 security level 3 and specifies security controls addressing intentional violation by threat actors possessing moderate resources and specific OT-system skills.
- Security profile 4 (SP4) is based on IEC 62443 security level 4 and specifies security controls addressing intentional violation by threat actors possessing extended resources, high motivation, and specific OT-system skills.

4 System under consideration (SuC)

For all variants of class notation **Cyber secure**, the expression 'system under consideration' (SuC) is a collective term for all computer-based systems and equipment in the scope. Hence, there will always be only one SuC in a project and the SuC will typically consist of many computer-based systems and equipment, some of which are interconnected, and others may be 'stand-alone'.

The SuC will consist of computer-based systems as follows:

- 1) Default SuC: computer-based systems and equipment providing control, monitoring, alarming and/or protective safety functions for the mandatory vessel functions listed in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 9](#).
- 2) Additional SuC (if applicable): other computer-based systems selected by way of the optional notation qualifier +. Examples of such additional systems are listed in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 10](#).

Guidelines for determining systems in the SuC are described in [Sec.4 \[2.2\]](#).

5 Class notation variants

5.1 General

One of the three below variants of the DNV class notation may be selected for a vessel. All the variants will have the same default SuC and the same requirements for cyber security management system (CSMS) in the operational phase, hence the differences between the class notation variants are given by the security profiles (i.e. the extent of required technical security controls).

5.2 Cyber secure

For class notation **Cyber secure** the default SuC is required to meet security profile 0 (SP0). This class notation is considered to meet the intention of MSC.428(98) and may be particularly relevant for vessels in operation (alteration projects) which seek to only conform to the guidance in IMO Res. MSC.428(98) and MSC_FAL.1/Circ 3.

5.3 Cyber secure(Essential)

For class notation **Cyber secure(Essential)** the default SuC is required to meet security profile 1 (SP1). This class notation is aligned with IACS UR E26 and UR E27 and is mandatory for vessels specified in [DNV-RU-SHIP Pt.1 Ch.2](#) contracted on or after 2024-07-01.

5.4 Cyber secure(Advanced)

For class notation **Cyber secure(Advanced)** the default SuC is required to meet security profile 3 (SP3). This class notation may currently be difficult to achieve for most vessels because the computer-based OT-systems in the SuC may not be designed with such advanced security controls. However, SP3 may be selected for certain systems/security zones by use of notation qualifier + in [\[6\]](#).

6 Additional qualifier +

As per the initial risk assessment in [Sec.4 \[2.1\]](#), class notation qualifier + may be amended to any of the above class notation variants. The qualifier signifies that additional systems have been included in the system under consideration (SuC) or that selected systems in the SuC is required to meet the requirements of a specified higher security profile. The class notations will in such case be:

- **Cyber secure(+)**
- **Cyber secure(Essential, +)**
- **Cyber secure(Advanced, +)**.

When the notation qualifier + is used, the additional systems and the security profile shall be specified. See also [Sec.4 \[2.1.3\]](#) and [Sec.4 \[2.1.4\]](#).

7 Overview of implementation and verification activities

7.1 General

The following subsections illustrate and summarize the implementation activities expected carried out by the various stakeholders and the verification activities carried out by the Society.

7.2 Product certification activities

Guidelines for suppliers of computer-based systems and equipment are provided in [Sec.3](#). These activities are summarized in [Figure 3](#).

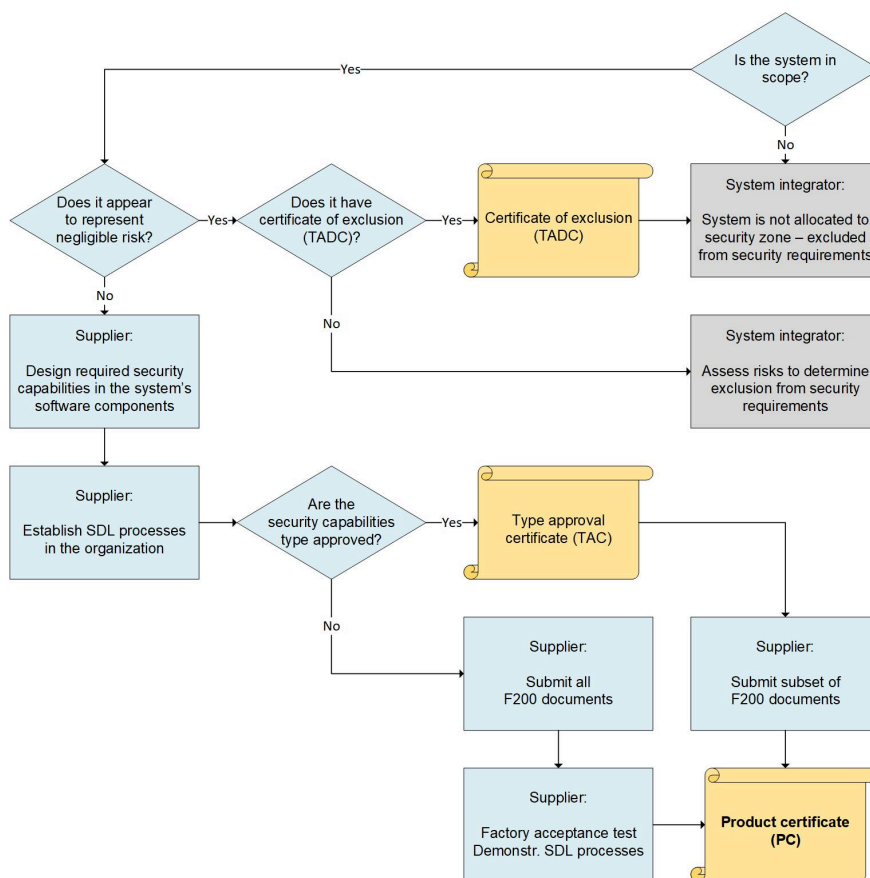


Figure 3 Product certification activities

7.3 Newbuilding project activities

Guidelines for the role systems integrator in newbuilding projects are provided in [Sec.4](#). These activities are summarized in [Figure 4](#).

For projects with SP0, product certification of computer-based systems in the SuC is not required, hence documents F031, F011, F071, and F251 shall fully include the computer-based systems in the SuC.

----- **Newbuilding projects. Stakeholder: Systems integrator. See DNV-CG-0325 Section 4.** -----

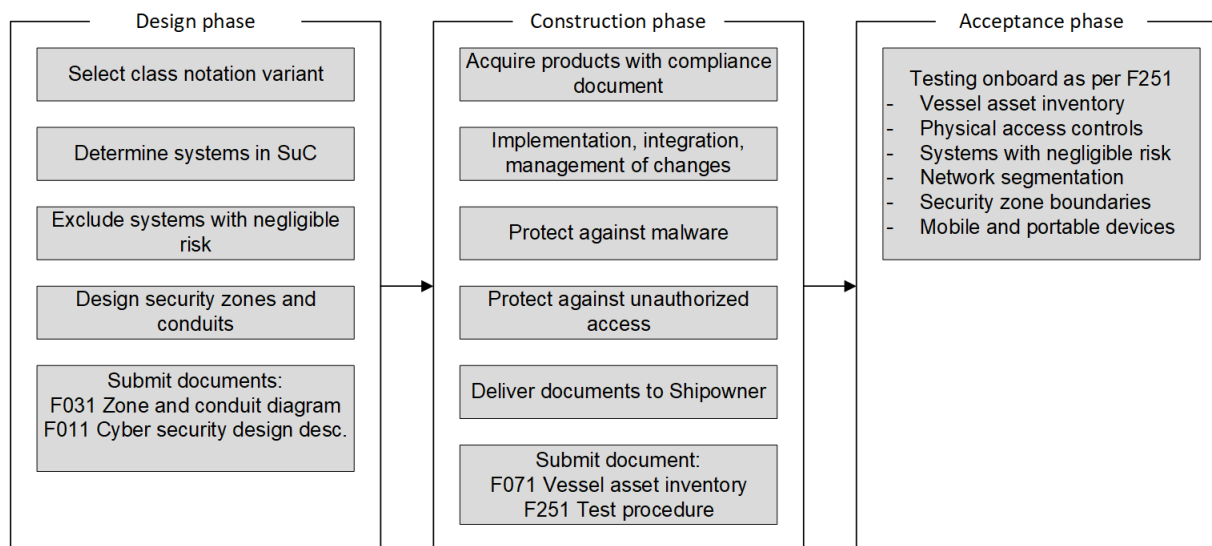


Figure 4 Newbuilding project activities

7.4 Alteration project activities

Guidelines for the role systems integrator in alteration projects are provided in [Sec.5](#). These activities are summarized in [Figure 5](#).

For alteration projects, product certification is normally not applicable, hence documents F031, F011, F071, and F251 shall fully include the computer-based systems in the SuC.

----- Alteration projects. Stakeholder: Systems integrator. See DNV-CG-0325 Section 5. -----

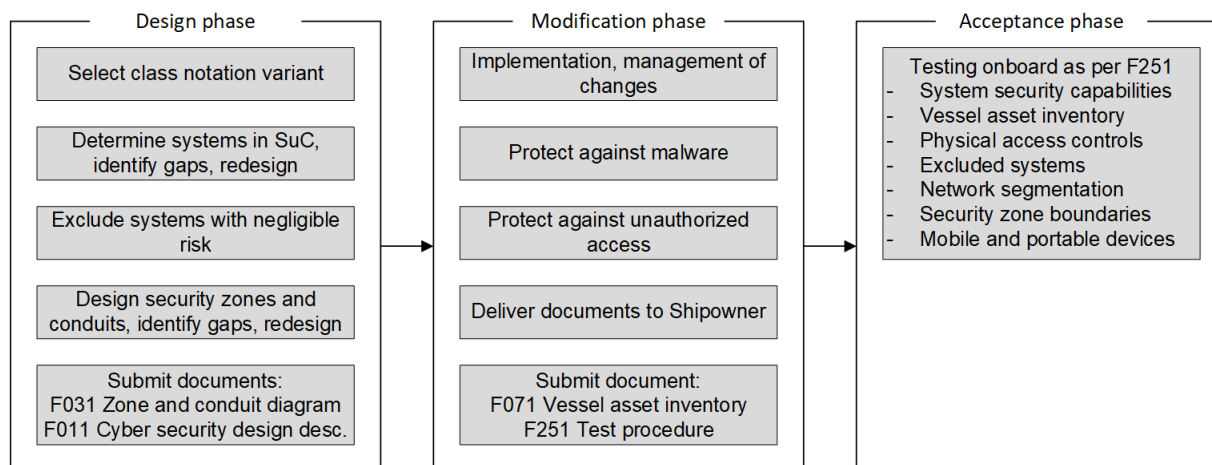


Figure 5 Alteration project activities

7.5 Activities in the operation phase

Guidelines for shipowners and operators on how to manage cyber security in accordance with the in-operation class notation **CSMS** are provided in [Sec.6](#). These activities are summarized in [Figure 6](#).

----- Operation. Stakeholder: Shipowner. See DNV-CG-0325 Section 6. -----

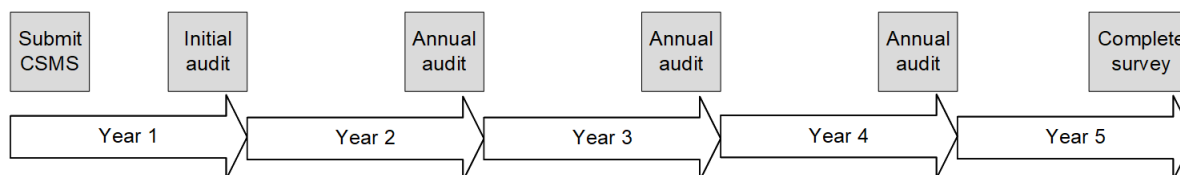


Figure 6 Activities in the operation phase

SECTION 3 COMPLIANCE DOCUMENTS

1 Introduction

This section provides guidance for the mandatory compliance document product certificate (PC) and explains how the voluntary compliance documents type approval certificate (TAC) and type approval design certificate (TADC) may be applied in projects with applicable cyber security requirements.

Product certification applies for computer-based systems that are required to meet SP1 or higher and that are delivered to a NB projects, see [Sec.4](#). Product certification would also apply for a new computer-based system that is required to meet SP1 or higher and that replaces an existing system in an alteration project, see [Sec.5](#).

2 Compliance documents

2.1 Product certificate (PC)

A Product certificate (PC) confirming compliance with applicable cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#) is mandatory for each delivery (case-by-case) of computer-based systems in the SuC required to meet SP1 or higher.

2.2 Type approval certificate (TAC)

Devices or computer-based systems may obtain a TA certificate (TAC) confirming compliance with the requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#). The TAC will cover case-by-case verification activities in the product certification process as per [\[3.2\]](#) and [\[3.3\]](#). The TAC is voluntary, and the process is described in [DNV-CP-0231](#).

2.3 Type approval design certificate (TADC)

In the context of the rules for class notation **Cyber secure**, a TADC is voluntary and may only be used to confirm that a computer-based system or equipment meets the criteria for negligible risk in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[2.2\]](#), see [Sec.4 \[2.3\]](#).

3 Product certification

3.1 Certification process

3.1.1 General

Product certification is a case-by-case verification process applicable for each delivery to DNV classed vessels of a computer-based system in the SuC. The main verification activities are:

- assessment of documentation
- manufacturing survey.

The agreement for product certification is established between the supplier of the computer-based system and the local DNV office.

Guidance note:

The systems integrator is also considered a supplier if a computer-based system in the SuC is acquired, installed, and integrated on board by the systems integrator.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

The verification activities are described in [\[3.1.2\]](#) and [\[3.1.3\]](#).

3.1.2 Assessment of documentation

Requirements for documents to be submitted are specified in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[1.8.2\]](#), see [DNV-CG-0550](#) for description of the expected content of the documents.

Table 1 Assessment of documentation

<i>Documents/information</i>	<i>with TA</i>	<i>without TA</i>
F030 - System topology	x	x
F071 - Inventory list	x	x
F021 - Description of security capabilities		x
F141 - Guidelines for hardening and configuration of security capabilities		x
F252 - Procedure for test of security capabilities		x
F259 - Description of secure development lifecycle (SDL) processes		x
I320 - Software change handling procedure		x
F253 - Procedure for verification of security functions on board		x
F142 - Information supporting incident response and recovery		x
Z261 - Test report, or Z300 - Declaration, demonstrating that hardening of the system and configuration of security capabilities have been carried out by the manufacturer and/or supplier of the system, as per F141	x	

For computer-based systems with type approved security capabilities, most of the documentation required to be submitted for product certification will be covered by the TAC as illustrated in [Table 1](#). The intention with assessment of documents F030 and F071 for systems with type approved security capabilities is to verify that the system to be delivered is correctly represented by the type approved design. The intention with document Z261/Z300 is described in [\[3.1.3\]](#).

3.1.3 Manufacturing survey

Requirements for the manufacturing survey are specified in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[5.2\]](#).

Table 2 Manufacturing survey

<i>Verification activity</i>	<i>with TA</i>	<i>without TA</i>
Test of security capabilities as per F252		x
Demonstration of security configuration as per F141	x	x
Demonstration of secure development lifecycle (SDL) processes as per F259		x

For computer-based systems with type approved security capabilities, the scope of the manufacturing survey is to demonstrate that security capabilities are configured correctly, as per document F141. This demonstration of security configuration may be based on assessment of document Z261/Z300, see [Table 1](#). In such cases, manufacturing survey verifying compliance with security requirements will not be required.

3.2 Documents provided to the systems integrator

The supplier should ensure the below documents are delivered to the systems integrator together with the system:

- F030 System topology.

- F071 Inventory list.
- F253 Procedure for verification of security controls on board. This documentation should include user manuals or instructions to be delivered together with the system enabling the shipowner to check that required security controls are working as intended. This document may be combined with F142.
- F142 Information supporting incident response and recovery. This documentation should include user manuals or instructions to be delivered together with the system enabling the shipowner to respond to and recover from cyber incidents. These manuals should address local controls, network isolation, post incident forensics, deterministic output/fail-safe response, backup, and restore/recovery.

3.3 Further guidance on systems with TAC

If the system's security capabilities are not fully covered by a TAC, i.e., the system's architecture, hardware and/or software components are not the same as in the type approved system, the differences should be described in the relevant F200 documents.

If the system has been subject to minor modifications compared to the TAC, this is acceptable as long as these changes are managed in accordance with the type approved modification strategy and procedure for management of change (I320).

For standard and routinely manufactured systems, type approval of security capabilities is highly recommended since this will allow for significant reduction of verification in the project-specific product certification process.

Type approval is recommended for devices such as switches, routers, firewalls, and PLCs that will be part of a computer-based system. This will enable system suppliers to acquire devices with the necessary security capabilities as well as guidelines or instructions for configuration of the security capabilities.

4 Requirements for product certificate

4.1 General

A computer-based system is required to be delivered with a product certificate (PC) when stated in the applicable DNV rules.

When a PC is required for the same system by multiple parts of DNV rules, there may be one combined product certification process such that the PC covers all applicable requirements to the system.

[4.2] to [4.11] provide guidance on how to determine if a system or equipment is required to be delivered with a product certificate (PC) confirming compliance with the cyber security requirements. The following general guidelines apply:

- 1) The requirement for product certification of security controls applies to computer-based systems that are part of the SuC and that are required to meet requirements of security profile 1 (SP1) or higher.
- 2) The product certification will cover security capabilities, architecture, and communication interfaces for the system and its assets (e.g. host devices, embedded devices, network devices, software applications, and managed field devices).
- 3) Product certification is required for computer-based systems delivered by a system supplier. Such systems would typically consist of multiple hardware and software components, some of which may be developed by the system supplier while others are acquired from sub suppliers.
- 4) Product certification is required for computer-based systems provided by the system integrator. Such systems would typically consist of multiple hardware and software components acquired from sub suppliers and integrated to form a computer-based system by the systems integrator. See e.g. [4.6].
- 5) Product certification is not required for individual hardware and software components (e.g. PLCs, network switches, operating systems) delivered by sub-suppliers to a system supplier or to a systems integrator. However, if the hardware and software components are used in a computer-based system in the SuC, they will need to have the required security capabilities. Hence type approval of the components would be recommended.

- 6) Product certification is not required for computer-based systems that have been approved to constitute negligible cyber risk.
- 7) Field equipment connected to systems in the SuC is required to have the required security capabilities. Product certification of the system should include the field equipment if it is delivered together with the system. See [4.10].

4.2 Control systems

Control, monitoring, and/or alarm systems for functions in the default SuC are, if installed on board, required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#). A listing of relevant systems is given in [App.A Table 1](#).

These control systems are generally also required to be delivered with a PC confirming compliance with other applicable DNV rules.

4.3 Electrical systems

Computer-based systems needed for generation and distribution of electrical power are required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#). A listing of relevant systems is given in [App.A Table 2](#).

These electrical systems are generally also required to be delivered with a PC confirming compliance with other applicable DNV rules.

4.4 Fire safety systems

Computer-based systems needed for fire detection and extinguishing are required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#). A listing of relevant systems is given in [App.A Table 3](#).

These systems are also required to meet statutory regulations, i.e. they are required by the administration to be of an approved type, e.g. MED certificate or type approval certificate.

4.5 Other safety systems

Safety systems are required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#). A listing of relevant systems is given in [App.A Table 4](#).

These safety systems are generally also required to be delivered with a PC confirming compliance with other applicable DNV rules.

4.6 Navigation systems and equipment

Navigational systems are required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#) or the alternative standard IEC 61162-460. A listing of relevant systems is given in [App.A Table 5](#).

These systems are also required to meet statutory regulations, i.e. they are required by the administration to be of an approved type, e.g. MED certificate or type approval certificate.

Manufacturers of navigational equipment should ensure the equipment has type approved security capabilities. The stakeholder being responsible for integrating the navigational equipment in a system should install and configure the components in accordance with the manufacturer's instructions and configuration guidelines.

If the navigational equipment is delivered by a system supplier, the system supplier should obtain one common PC covering all navigational equipment in the delivery.

If the navigational equipment is acquired by the systems integrator and installed/integrated on board, the systems integrator should obtain one common PC covering all navigational equipment.

It should be noted that the design of security zones and conduits will need to take into account the security standard applied for the navigational systems and equipment. See [Sec.4 \[2.4.7\]](#).

4.7 Internal communication systems

Internal communication systems are required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#). A listing of relevant systems is given in [App.A Table 6](#).

These systems are also required to meet statutory regulations, i.e. they are required by the administration to be of an approved type, e.g. MED certificate or type approval certificate.

4.8 External communication systems

External communication systems are required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#) or the alternative standard IEC 61162-460. A listing of relevant systems is given in [App.A Table 7](#).

These systems are also required to meet statutory regulations, i.e. they are required by the administration to be of an approved type, e.g. MED certificate or type approval certificate

It should be noted that the design of security zones and conduits will need to take into account the security standard applied for the external communication system. See [Sec.4 \[2.4.7\]](#).

4.9 Other systems

Other computer-based systems that may have been added to the SuC by use of the notation qualifier + are, if installed on board, required to be delivered with a PC confirming compliance with cyber security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21](#). Examples of such systems are:

- DP control system
- auxiliary thruster control system
- drilling control system
- cargo control system
- ballast water treatment system
- SOx and NOx emission control systems.

4.10 Field equipment

Field equipment is typically sensors, analyzers, actuators, and instrumentation in level 0 or 1 of the purdue enterprise reference architecture (PERA).

Software-based field equipment connected to systems in the SuC should have inherent security controls as per [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[4\]](#), as applicable.

Manufacturers of such field equipment are recommended to type approve the device's security capabilities. The stakeholder responsible for integrating the field equipment in a system should install and configure the device in accordance with the manufacturer's instructions and guidelines for the configuration of the security capabilities.

If such field equipment is part of a computer-based system delivered by a system supplier, the PC for the system should also include the field equipment.

4.11 Devices representing negligible risk

In the computer-based systems and equipment above, some software-based devices in a system may be considered to represent negligible cyber risk and may be excluded from all or parts of the requirements.

In such cases, the stakeholder responsible for obtaining product certificate (PC) should assess the risks associated with the device as per [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[2.2.2\]](#).

Since the class notation is based on the defense in depth principle, it is not sufficient to rely only on physical access controls. The following risks and threat surfaces should at least be addressed:

- Communication with other systems or components, risks associated with propagation of cyber incidents should be considered, including potential impacts deriving from a cyber incident in the connected system or component.
- Physical access controls, risks associated with unauthorized access to the device should be considered.
- Physical or logical interfaces, risks associated with unauthorized access to management services should be considered (providing e.g. configuration and software update) via HMI display or via interface ports such as, USB, COM, and ethernet.

SECTION 4 NEWBUILDING PROJECTS

1 Introduction

1.1 General

This section describes how to implement the class notation **Cyber secure** in newbuilding projects.

1.2 Project phases

The implementation of the class notation **Cyber secure** should be executed as per the main phases and activities, see [Table 1](#) to [Table 3](#).

Table 1 Design phase

<i>Design activities</i>	<i>Ref.</i>	<i>Society's rules</i>
Select class notation variant	[2.1]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [1.4]
Determine systems in SuC	[2.2]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [2]
Exclude systems with negligible risk	[2.3]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [2.2]
Design security zones and conduits	[2.4]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [3.2]
Submit documents F031, F011	[2.5]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [1.8.1]

Table 2 Construction phase

<i>Implementation activities</i>	<i>Ref.</i>	<i>Society's rules</i>
Acquire products w/compliance document	[3.2]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [1.8.3]
Implementation, integration, management of changes	[3.3]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.3.2]
Protect against malware	[3.4]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.3.3]
Protect against unauthorized access	[3.5]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.1.2]
Deliver documents to shipowner	[3.6]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.3.6]
Submit documents F251, F071	[3.7]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [1.8.1]

Table 3 Acceptance phase

<i>Test activities</i>	<i>Ref.</i>	<i>Society's rules</i>
Vessel asset inventory	[4.1.2]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.3]
Physical access controls	[4.1.3]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.6]
Systems with negligible risk	[4.1.4]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.18]
Network segmentation	[4.1.5]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.8]
Security zone boundaries	[4.1.6]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.9]
Mobile and portable devices	[4.1.7]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.14]

1.3 Roles

The design, construction and test activities described in this section are expected to be carried out by the systems integrator unless otherwise specified. However, other roles are also expected to contribute to a newbuilding project:

- Shipowner: company which will own the vessel/unit after delivery from the shipyard. If another company operates the vessel after delivery, the cyber security management system will be implemented and operated by this operator.
- Systems integrator: company responsible for design, installation, integration and testing activities on board. In a newbuilding project, this role is typically performed by the shipyard.
- Supplier: company supplying computer-based systems and equipment that is part of the SuC.
- Society: DNV is the independent classification society verifying compliance with the rules for class notation **Cyber secure**, including applicable notation qualifier.

2 Design phase

2.1 Select class notation variant

2.1.1 General

Before signing the contract for classification, an initial risk assessment should be carried out to select the appropriate class notation variant. In addition to assessing safety and environmental risks, other risks like financial risk, reputation risk, etc. may be taken into consideration.

IMO Res. MSC.428(98) and guideline IMO MSC-FAL.1/Circ 3 provide high-level recommendations for maritime cyber risk management.

DNV class notation **Cyber secure** meets these recommendations by providing a framework for addressing cyber risks using different notation qualifiers **Essential**, **Advanced**, and **+** as described in [Sec.2 \[5.3\]](#), [Sec.2 \[5.4\]](#) and [Sec.2 \[6\]](#).

The initial risk assessment should consist of three main tasks, as per [\[2.1.2\]](#) to [\[2.1.4\]](#).

This initial risk assessment is voluntary. The Society will not request this assessment or other documentation that forms the basis for selecting a variant of class notation **Cyber secure**.

2.1.2 Risk assessment - default SuC

The first part of the initial risk assessment should be to evaluate risks associated with cyber security incidents affecting the vessel functions of the default SuC, see [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 6](#).

The class notation variant should be selected as per the following general principles:

- Class notation variant **Cyber secure(Essential)** should be selected if cyber risks associated with default SuC are found to be low or medium.
- Class notation variant **Cyber secure(Advanced)** should be selected if cyber risks associated with default SuC are found to be high or very high. Before choosing this class notation, it is recommended to carry out a screening of computer-based systems in the SuC to ensure that they can meet the required technical security controls.

The class notation variant **Cyber secure**, without notation qualifier, is not aligned with IACS UR E26 and UR E27 and may consequently not be selected for new vessels contracted after 2024-07-01, see [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 1](#) for vessel types required to meet these unified requirements.

For guidance on how to carry out the risk assessment, see to other references e.g. [DNV-RP-0496](#) or IEC 62443-3-2.

2.1.3 Risk assessment - other vessel function

The second part of the initial risk assessment should be to determine if the default SuC is sufficient to address the risks for the vessel. If other vessel functions than the default SuC are needed to manage the vessel's cyber risks, additional computer-based systems should be added to the SuC.

Examples may be DP control system, cargo control system, or drilling control system as specified in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 10](#). The class notation will indicate such additional systems by the notation qualifier +.

Since the class notation is a specification intended for operational technology (OT), the additional systems should be computer-based systems or equipment that interact with the physical environment (see definition of operational technology by NIST in guidance note below).

Guidance note:

NIST SP 800-37 Rev.2 *Operational technology*:: programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems/devices detect or cause a direct change through the monitoring and/or control of devices, processes, and events. Examples include industrial control systems, building management systems, fire control systems, and physical access control mechanisms.

---e-n-d---o-f---g-u-i-d-a-n-c-e---n-o-t-e---

2.1.4 Additional risk reduction

The third-part of the initial risk assessment should be to evaluate if any of the systems in the SuC represent higher cyber risk than specified by the selected class notation variant.

Such systems should meet the requirements of a higher security profile (e.g. SP2) and shall be allocated to a separate security zone. The class notation will indicate such systems and the assigned security profiles by the notation qualifier +.

2.2 Determine systems in SuC

A computer-based system is not limited to a group of devices connected to each other via networks or serial links but may also consist of other equipment such as a single isolated device designed for control or monitoring of machinery on board. Examples may be software-based field instruments or electrical drives.

Managed devices such as network switches, firewalls, gateways, and converters are part of the SuC if these are used in the integration of the required computer-based systems.

The outcome of this activity should be a list of all potential computer-based systems and equipment identified as per the following steps:

- 1) Identify all systems and equipment in [App.A](#) that will be installed on board.
- 2) Identify any systems or equipment other than those listed in [App.A](#) needed to maintain operation of the required vessel functions in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 9](#).
- 3) Identify systems and equipment voluntarily included in the SuC by notation qualifier + as per [\[2.1.3\]](#).
- 4) Identify any other non-mandatory systems or equipment that will be allocated to a security zone.

In addition to the above steps, the systems integrator should identify any systems and equipment that will communicate with systems in the SuC. Such systems are considered untrusted and represent a threat surface, see [\[2.4.4\]](#). Examples may be e.g.:

- condition-based monitoring systems
- ballast water management systems
- cargo control systems.

After the systems and equipment in the SuC have been identified, a risk assessment should be carried out to determine if any of the systems may be excluded from the security requirements based on negligible cyber risk, see [\[2.3\]](#).

In the project acquisition process, the systems integrator should specify that suppliers deliver systems with compliance document PC (product certificate) issued by the Society, see [Sec.3](#).

2.3 Exclude systems with negligible risk

2.3.1 General

When the systems and equipment in the SuC (and respective suppliers) have been identified, the design and arrangement of the systems should be assessed to determine if any of the computer-based systems or equipment may be considered to represent negligible cyber security risk.

A system representing negligible cyber security risk should be considered in the following way:

- the system is excluded from meeting the security requirements
- the system is still considered part of the SuC and risks associated with this system are required to be managed in the operation phase of the vessel
- the system is not part of a security zone.

The risk assessment should be carried out for each system that is proposed excluded and it should be carried out by the systems integrator in cooperation with the respective supplier. The risk assessment(s) should be documented in document cyber security design description (F011) and submitted to the Society for approval.

Risk assessments carried out for a particular project are only valid for the given project. The systems integrator should not re-use such risk assessments in subsequent projects without having reassessed the risks.

System suppliers may seek approval of exclusion from the cyber security requirements by obtaining a type approval design certificate (TADC), see [Sec.3 \[2.3\]](#). In such case, the systems integrator should still ensure that the TADC is valid for the system delivered to the given project as well as ensuring that any conditions or limitations in the TADC are fulfilled for the given project.

A TADC confirming that the system can be excluded from the cyber security requirements will not be offered to systems that are capable of meeting the cyber security requirements.

2.3.2 Acceptance criteria

Cyber security risk is considered a combination of the following factors:

- threat surfaces (vulnerabilities or weaknesses giving rise to cyber threats)
- consequences (of threat surfaces being exploited).

To conclude that a system constitutes negligible cyber security risk, all criteria in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[2.2\]](#) should be evaluated and fulfilled. [Table 4](#) intends to specify a prescriptive method for determining whether a system has been designed and implemented with sufficiently limited threat surfaces and whether the consequences of a cyber incident would be acceptable from an operational and safety perspective.

Table 4 Method to determine negligible risk based on threat surface and consequences

No.	System characteristics	Threat surfaces/consequences
1	The system does not communicate with other computer-based systems or equipment via IP-network.	Criterion 1 - threat surface related to system architecture and communication
2	The system should not receive from other systems, data that is used for control/safety of equipment serving essential vessel services.	
3	The system does not have a significant internal attack surface. E.g., the system's network is confined to one or two cabinets located in the same room.	

No.	System characteristics	Threat surfaces/consequences
4	The system is installed in locations with means to limit physical access to authorized personnel. Instrument rooms or equipment rooms in which computer-based systems are installed should be equipped with lock on the doors. Locations that are normally manned during operation should also have door locks or other means to prevent unauthorized access when the vessel is at quay or in maintenance, etc.	Criterion 2 - threat surfaces related to location and physical installation
5	The system does not have physical HMI display(s) with capabilities for management functions such as configuration and software update.	Criterion 3 - threat surfaces related to physical and logical interfaces
6	The system does not have physical ports through which files can be transferred to the system, or management interfaces exposed. Software or configuration cannot be updated. Exceptions may apply if: — The software and configuration is stored in non-volatile read-only memory (e.g. ROM, PROM, EPROM). Updating software or configuration requires installation of new read-only memory inside the system's devices. — The software and configuration is signed by the manufacturer. Updating software or configuration is only possible if the configuration is built into the executable signed code that shall be successfully verified by the system. The signature should employ cryptographic algorithms with key sizes according to commonly accepted security industry practices and recommendations. — It is otherwise demonstrated by project-specific risk assessment that any interfaces do not represent threat surfaces, that potential consequences of a cyber incident of the system will not lead to hazardous situations or failure or loss of important or essential services, and that personnel on board will be able to detect and cope with data or functionality that has been manipulated by unauthorized persons or software.	
7	The system does not serve multiple vessel functions.	Criterion 4 - consequences of a cyber incident
8	The system does not have any known vulnerabilities that, if exploited, may lead to loss or failure of essential or important vessel functions.	

2.4 Design security zones and conduits

2.4.1 General

A security zone is a grouping of logical or physical assets based upon risk or other criteria, such as criticality of assets, operational function, physical or logical location, required access (for example, least privilege principles) or responsible organization, see 62443-3-2. A security zone may comprise multiple networks, systems and equipment, all of which are subject to the same requirements. A conduit is a communication channel traversing the boundary of a security zone.

Security zones will allow for segregation of systems based on criticality and risk. Well-defined zones will also allow for containment of cyber incidents.

Conduits between security zones will enforce access control measures, control data traversing the zone boundaries, monitor and log traffic and security events. Conduits between security zones and untrusted networks will in addition, ensure secure communication pathways between endpoints and enforce stronger access control measures.

Following the requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[4.6.1\]](#), there shall, as a minimum, be three separate OT security zones for a vessel:

- security zone for control, monitoring and alarm systems
- security zone for safety systems
- security zone for navigational and radiocommunication systems.

In addition, separate security zones would be needed for:

- wireless networks
- systems approved in accordance with other equivalent security standards
- systems specified to meet higher security profile by use of notation qualifier +.

2.4.2 Zones and security profiles

When designing a security zone, the systems integrator should identify all computer-based systems and equipment that are allocated to the zone. The vessel asset inventory (document code F071) should identify the security zone to which each system/equipment is allocated.

Furthermore, all systems and equipment in the zone shall meet the same technical requirements (security profile) and follow the same policies in the cyber security management system (CSMS).

Additional systems that have been added to the SuC by way of the notation qualifier + may be allocated to the same zone as systems in the default SuC, provided all systems in the zone meet requirements of the same security profile.

Systems that are specified to meet the requirements of a higher security profile than given by the class notation variant (by way of the notation qualifier +) shall be allocated to one or more separate security zones.

2.4.3 Network segmentation and zone boundary protection

There may be multiple networks in one security zone. These networks may be connected to each other or isolated.

If an IP-based network in a security zone will be connected to another security zone, the networks shall be physically or logically segmented into different broadcast domains and the networks shall be interconnected by a zone boundary protection device (i.e., a router/firewall). See [2.4.4], [2.4.6], and [2.4.8] for physical segmentation.

The data traversing the zone boundaries shall be controlled in accordance with the principle of 'deny by default, allow by exception'. The firewall should at least control the traffic based on source and destination IP addresses, protocol, and port numbers.

In general, data may be exchanged between security zones using other communication protocols (e.g., serial communication) without specific means to protect the zone boundaries. This does not apply when routed IP-traffic is converted to serial protocol, in which case zone boundary protection is required.

In addition to the above, the security zones should be designed such that it is possible to terminate the communication across zone boundaries without loss of essential vessel services or safety functions, see IACS UI SC134.

2.4.4 Communication with untrusted networks

If a security zone will be connected to an untrusted network or equipment, the networks should be physically segmented and interconnected by a zone boundary protection device (i.e. a router/firewall).

In addition, such conduits should use secure communication protocols, ensuring authentication of the endpoints and cryptographic integrity protection. These additional requirements are:

- SR 1.2 identification and authentication of software processes and devices
- SR 3.1 RE1 cryptographic integrity protection
- SR 3.5 input validation
- SR 3.8 session integrity
- SR 3.8 RE1 invalidation of session IDs after session termination
- SR 4.1 RE1 protection of confidentiality (for SP2 and higher security profiles).

To protect the security zones against threats from untrusted networks, the untrusted networks should not send to the security zone any data that is used for control/safety of equipment serving essential vessel

services. This applies regardless of communication protocol/principle. Any data sent to/from untrusted networks should be described in document F011.

As specified in [2.2], some non-mandatory systems may need to be allocated to a security zone because they cannot communicate with the security zones using secure communication protocols. This means such systems shall meet the security requirements.

2.4.5 Remote access

Solutions providing human access to a security zone from other networks (e.g., from IT-networks on board or from supplier's offices on shore) shall meet the following requirements:

- SR 1.1 RE2 multifactor authentication
- SR 1.11 unsuccessful login attempts
- SR 1.12 system use notification
- SR 1.13 access via untrusted networks
- SR 1.13 RE1 explicit access request approval
- SR 2.6 remote session termination.

It is recommended that the system(s) used for remote access to a security zone in addition follow requirements:

- SR 3.2 malicious code protection
- SR 2.8 auditable events
- SR 7.7 least functionality.

2.4.6 IT-Systems

IT-systems should not be allocated to an OT-security zone. If an IT-system is added to the class notation by way of the notation qualifier +, the system is required to form one or more separate security zones. Examples of IT-systems are:

- administrative systems for personnel on board
- entertainment systems
- surveillance and access control systems
- communication systems for crew and passengers
- satellite communication systems.

Devices that protect zone boundaries (i.e. firewall on the border between an OT-zone and an IT-network) shall be designed to meet the requirements of the OT-security zone.

If a network includes both IT-functions and OT-functions, where only the OT-functions are subject to the cyber security requirements, the system/network should be separated into two zones (one untrusted IT-zone and one trusted OT-zone). An example of systems that may host both IT and OT-functions is an IP-telephone system that includes two-way communications between cabins, offices, emergency control stations, muster and embarkation stations and strategic positions on board.

2.4.7 Navigation and communication systems

Systems and equipment required to meet statutory regulations for navigational and radiocommunication functions (e.g. in SOLAS chapter V and IV) are required to be allocated to one or more separate security zones. See list of systems in App.A [1.6], App.A [1.7], and App.A [1.8].

For the class notations **Cyber secure** and **Cyber secure(Essential)**, the navigation and/or radiocommunication zone(s) may be designed according to IEC 61162-460 instead of the security requirements in DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [4].

All systems and equipment within a 460-zone shall meet the requirements of IEC 61162-460. Communication between the 460-zone and other trusted security zones shall be implemented by use of 460-Forwarder or a 460-Gateway. Communication between the 460-zone and untrusted networks shall be implemented by use of or a 460-Gateway.

Devices in a 460-zone should be type approved in accordance with the 460-standard. If a node in the 460-network/zone does not meet the requirements for a 460-node, a case-by-case approval may be acceptable

if relevant security requirements in IEC 61162-460 chapter 6 are still met. It is generally not acceptable to compensate for lacking security controls in IEC 61162-460 chapter 6 by compensating countermeasures. For the class notation **Cyber secure(Advanced)**, the navigation and/or radiocommunication zone(s) are required to meet the Society's rules (SP3).

2.4.8 Safety systems

Fire safety systems and other safety systems are required to be allocated to one or more separate security zone(s). See list of systems in [App.A](#).

For computer-based systems providing both control and safety functions (e.g. engine control and safety system), the safety functions shall be implemented in a dedicated device arranged in accordance with the requirements for network segmentation and zone boundary protection. The safety controller would in such cases constitute a separate security zone.

2.4.9 Wireless systems

Where wireless devices are included in the SuC, these shall be allocated to a separate wireless security zone. Such devices should only communicate via the wireless network, i.e. not have multiple network interfaces ('dual homed').

Communication between the wireless security zone and other security zones or networks should be controlled by a zone boundary protection device (firewall).

2.4.10 Sheep dip station

If a device is installed for the purpose of detecting and removing malware from USB flash drives, portable computers or other devices that may be connected to devices in the security zones, this device should be allocated to a separate zone, e.g. a de-militarized zone (DMZ).

2.5 Submit documents F031 and F011

The design documents F031 (zone and conduit diagram) and F011 (cyber security design description) are required submitted for approval as per [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 6](#). The expected content of these documents is described in [DNV-CG-0550 Sec.5](#). It is recommended that the systems integrator submits the first version of F031 and F011 for approval early in the project.

3 Construction phase

3.1 General

During vessel construction and commissioning the systems integrator should manage cyber security of the SuC in accordance with [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[5.3\]](#). [\[3.2\]](#) to [\[3.7\]](#) provide additional guidance on the expected activities:

3.2 Acquire products with compliance document

The system integrator should ensure that systems in the SuC are delivered with compliance document PC as per [Sec.3](#).

If the systems integrator takes the role of a supplier, i.e. where the systems integrator acquires components and designs a system in the SuC, the requirements for product certification in [Sec.3](#) apply for the systems integrator.

If the systems integrator acquires and installs field devices, network devices, or other components for the purpose of systems integration, the systems integrator should ensure these components have the necessary security capabilities and are implemented and configured correctly. It is strongly advised to acquire components with type approved security capabilities - such components will be delivered with guidelines for the configuration of the security capabilities, see document F141 in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[1.8.2\]](#).

3.3 Implementation, integration, management of changes

The systems integrator should install and integrate the computer-based systems and equipment on board in accordance with approved design documents, installation manuals, and compliance documents issued to the suppliers.

The systems integrator should, during construction and commissioning, ensure that modifications to the systems and equipment in the SuC are managed in accordance with the principles in [DNV-RU-SHIP Pt.4 Ch.9 Sec.1 \[1.5\]](#), i.e. the following activities should be logged:

- reason for the modification
- specification of the modification
- assessment of the impact of the modification
- acceptance to implement the modification
- procedure for implementing the modification
- test report confirming successful implementation of the modification.

As part of this modification process, relevant documentation should be kept updated. Major changes affecting systems, equipment or security zones that have been approved should be submitted to the Society for verification.

3.4 Protect against malware

The systems integrator should, during construction and commissioning ensure that software for malware protection is kept updated and that use of mobile and portable devices is prevented or controlled as per SR 2.3.

3.5 Protect against unauthorized access

The systems integrator should, during construction and commissioning, prevent unauthorized access to the systems and equipment in the SuC, e.g.:

- restrict physical access to authorized personnel
- ensure default passwords are changed
- ensure that any remote access is carried out in accordance with [\[2.4.5\]](#).

3.6 Deliver documents to shipowner

Upon delivery of the vessel to the shipowner, the systems integrator should ensure that updated versions of the following documentation are provided to the shipowner:

- F011 - cyber security design description
- F031 - zone and conduit diagram
- F071 - complete vessel asset inventory
- F251 - procedure for onboard testing.

Additionally, for each system in the SuC, the systems integrator should ensure that updated versions of the following documentation are provided to the shipowner:

- F030 - system topology
- F142 - user manuals and instructions supporting incident response and recovery
- F253 procedure for verification of security functions

The above documents should be approved by the Society. Versions that have been updated due to minor changes (see [\[3.3\]](#)) need not be approved by the Society.

3.7 Submit documents F071 and F251

The documents F071 (vessel asset inventory) and F251 (test procedure) are required to be submitted for approval as per [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 6](#). The expected content of these documents is described in [DNV-CG-0550 Sec.5](#).

4 Acceptance phase

4.1 Testing on board

4.1.1 General

Before delivery of the vessel to the shipowner, the systems integrator should demonstrate to the Society compliance with the security requirements as per [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[5.4\]](#).

These tests should be carried out in accordance with the approved version of document F251 and should be done after commissioning activities and other tests have been successfully completed.

The following subsections provide guidance on these tests. It should be noted that this guidance assumes all systems in the SuC have been delivered with product certificates (PC), and that no open comments, conditions, or limitations are given in the product certificate or eventual type approval certificates.

If any systems or equipment in the SuC have been certified with open comments, conditions, or limitations by the Society, additional verification would be needed to ensure compliance with the security requirements.

4.1.2 Vessel asset inventory

The as-built version of the complete vessel asset inventory (F071) should be validated on board. It would normally not be possible to check type and version of each hardware and software component in all systems against the information in the vessel asset inventory, but a reasonable extent of sampling should be done. Focus may be given to verify that versions of operating systems, firmware and application software correspond with the asset inventory.

4.1.3 Physical access control

Computer-based systems in the SuC should be installed in a location onboard to which physical access can be controlled. Such locations are typically navigating bridges, engine rooms, engine control rooms, instrument rooms, fire control stations, etc.

The systems integrator should demonstrate that such locations have been equipped with means to limit physical access to only authorized personnel, i.e. locked rooms, and locked cabinets.

4.1.4 Systems with negligible risk

The systems integrator should demonstrate that all systems approved to represent negligible cyber risk meet the criteria in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[2.2\]](#). See also [\[2.3\]](#).

It is expected that approved risk assessments as per [\[2.3\]](#) and/or TADCs as per [Sec.3 \[2.3\]](#) are available on board (i.e. in the approved document F011).

4.1.5 Network segmentation

The systems integrator should demonstrate by testing that network segments in the security zones are confined to the respective zone, i.e. that logical or physical segmentation has been implemented as per [\[2.4\]](#).

Updated versions of relevant documents should be available during this test, e.g. system topology documents (F030), zone and conduit diagram (F031), and cyber security design description (F011).

It is expected that physical and logical network segments in each security zone are scanned (e.g. reachability scan) demonstrating that only known/expected host addresses are found on the network segment.

4.1.6 Security zone boundaries

4.1.6.1 General

The systems integrator should demonstrate by testing that security zone boundary protection has been implemented as per [2.4].

The zone boundaries and any protection devices should be identified onboard. Updated versions of relevant documents should be available during this test, e.g. system topology documents (F030), zone and conduit diagram (F031), and cyber security design description (F011).

4.1.6.2 Port scanning

It is expected that security zone boundaries are scanned, demonstrating that only documented and approved data flows are permitted to traverse the zone boundary, i.e. 'least privilege' (SR 7.7).

It is expected that firewall rules are demonstrated to meet the principle of 'deny all, allow by exception' (SR 5.2).

4.1.6.3 Denial of service

It should be demonstrated that security zones are protected from DoS attacks from the external side of the zone boundary protection devices. The DoS attacks should target the ports identified in [4.1.6.2].

4.1.6.4 Untrusted networks

The systems integrator should demonstrate by testing that communication with untrusted networks has been implemented as per [2.4.4].

It should also be demonstrated that data transferred from untrusted networks to a security zone, as described in F011, will not represent a risk if the untrusted system has been compromised, see [2.4.4].

4.1.6.5 Isolation of security zone

It should be demonstrated that security zones may be isolated without affecting the intended functionality of the systems within the zone.

This test may be omitted for security zones that have been approved with such inter-zone dependencies. Examples of such arrangements may be a zone consisting of an integrated navigation system where some of the navigational equipment is allocated to separate sub-zone(s).

4.1.7 Mobile and portable devices

The systems integrator should demonstrate any 'sheep dip station' and other external countermeasures controlling the use of mobile and portable devices. Security controls inherent in the certified systems need not be tested on board.

SECTION 5 ALTERATION PROJECTS

1 Introduction

1.1 General

Assignment of the class notation **Cyber secure** to an existing vessel is considered to be an alteration project.

The main difference between newbuilding projects, and alteration projects is that for an alteration project the technical installation (e.g. computer-based systems, networks) has not been designed and installed in accordance with the requirements for the class notation **Cyber secure**.

This section describes how to implement the class notation **Cyber secure** in vessels in operation.

1.2 Project phases

The alteration project should be executed as per the main phases and activities below, see [Table 1](#) to [Table 3](#).

Table 1 Design phase

<i>Design activities</i>	<i>Ref.</i>	<i>DNV rules</i>
Select class notation variant	[2.1]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [1.4]
Determine systems and equipment in SuC, identify gaps, redesign	[2.2]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [2]
Exclude systems with negligible risk	[2.3]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [2.2]
Design security zones and conduits, identify gaps, redesign	[2.4]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [3.2]
Submit documents F031 and F011	[2.5]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [1.8.1]

Table 2 Modification phase

<i>Modification and implementation activities</i>	<i>Ref.</i>	<i>DNV rules</i>
Implementation, management of changes	[3.1]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.3.2]
Protect against malware	[3.2]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.3.3]
Protect against unauthorized access	[3.3]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.1.2]
Deliver documents to shipowner	[3.4]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.3.6]
Submit document F071 and F251	[3.5]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [1.8.1]

Table 3 Acceptance phase

<i>Test activities</i>	<i>Ref.</i>	<i>DNV rules</i>
System security capabilities	[4.1.2]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.2]
Vessel asset inventory	[4.1.3]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.3]
Physical access controls	[4.1.4]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.6]

<i>Test activities</i>	<i>Ref.</i>	<i>DNV rules</i>
Systems with negligible risk	[4.1.5]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.18]
Network segmentation	[4.1.6]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.8]
Security zone boundaries	[4.1.7]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.9]
Mobile and portable devices	[4.1.8]	DNV-RU-SHIP Pt.6 Ch.5 Sec.21 [5.4.14]

Before start of the high level design, the class notation shall be decided as described in [Sec.4 \[2.1\]](#).

1.3 Roles

The design, modification, and test activities described in this section are expected to be carried out by the systems integrator unless otherwise specified. However, other roles are also expected to contribute in an alteration project:

- Shipowner: company which will own the vessel/unit. If another company operates the vessel after delivery, the cyber security management system will be implemented and operated by this operator.
- Systems integrator: company responsible for design, installation, integration and testing activities on board. In an alteration project, this role is typically performed by the shipowner.
- Supplier: company having supplied the computer-based systems and equipment that is part of the SuC.
- Society: DNV is the independent classification society verifying compliance with the rules for class notation **Cyber secure**, including any notation qualifier.

2 Design phase

2.1 Select class notation variant

The guidance in [Sec.4 \[2.1\]](#) on how to determine the appropriate variant of the class notation **Cyber secure** applies also for alteration projects.

However, unless the computer-based systems and network architecture are replaced or undergo major modifications, it will normally not be possible to achieve the most demanding security profiles.

2.2 Determine systems in SuC, identify gaps, redesign

The guidance in [Sec.4 \[2.2\]](#) on how to identify the computer-based systems and equipment in the SuC applies also to alteration projects.

When the SuC has been determined, the systems integrator should cooperate with relevant suppliers to identify gaps between existing security capabilities and technical security requirements. The systems should then be redesigned or upgraded as needed, and/or compensating countermeasures should be established for security controls that cannot be implemented. If a system in the SuC is replaced with a new system, the new system is required to be delivered with product certificate, see [Sec.3 \[3\]](#), otherwise, modifications should be carried out in accordance with [Sec.4 \[3.3\]](#).

For each system in SuC, compliance with applicable security requirements and any compensating countermeasures should be described in document F011 (cyber security design description).

2.3 Exclude systems with negligible risk

The guidance in [Sec.4 \[2.3\]](#) on how to determine the computer-based systems and equipment in the SuC that represents negligible risk applies also for alteration projects.

The risk assessment for each system that is found to represent negligible risk should be described in document F011 (cyber security design description).

2.4 Design security zones and conduits, identify gaps, redesign

The guidance in [Sec.4 \[2.4\]](#) on how to design security zones and conduits is, in general, also applicable to an alteration project.

However, for an alteration project, the installed network architecture may not have the physical or logical network segmentation and/or the necessary firewalls in place to establish the security zones as per the requirements. In such cases, the systems integrator should redesign the architecture in cooperation with relevant suppliers. Modifications should be carried out in accordance with [Sec.4 \[3.3\]](#).

2.5 Submit documents F011 and F031

Before starting the modification work on board, the systems integrator should submit the following design documents for verification and approval by the Society:

- F011 - cyber security design description
- F031 - zone and conduit diagram.

For an alteration project, the computer-based systems in the SuC will normally not be subject to product certification. The system topology diagram should be included in document F031 or in appendixes to F031. The description of how the systems comply with security requirements in [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[4\]](#) should be described in document F011 or appendixes to F011.

3 Modification phase

3.1 Implementation, management of changes

Computer-based systems and equipment will normally need to be reconfigured, modified, upgraded, or replaced. The systems integrator should ensure that documentation of such changes is produced and submitted to the Society for verification and approval. Systems that are replaced should be delivered with compliance document PC.

The modification work on board should be carried out by qualified personnel (typically the supplier), and in accordance with approved documentation, see [Sec.4 \[3.3\]](#).

3.2 Protect against malware

See [Sec.4 \[3.4\]](#).

3.3 Protect against unauthorized access

See [Sec.4 \[3.5\]](#).

3.4 Deliver documents to shipowner

See [Sec.4 \[3.6\]](#).

3.5 Submit documents F071 and F251

See [Sec.4 \[3.7\]](#). When the modifications have been implemented on board, the systems integrator should submit the following documents for verification and approval by the Society:

- F071 - vessel asset inventory
- F251 - test procedure.

For an alteration project, the computer-based systems in the SuC will normally not be subject to product certification. The test procedure for the systems should be included in document F251 or in appendixes to F251. The vessel asset inventory F071 should include all systems and equipment in the SuC.

4 Acceptance phase

4.1 General

For testing on board see [Sec.4 \[4.1\]](#)

4.2 System security capabilities

For alteration projects, the computer-based systems have not been subject to product certification of cyber security functions. Consequently, the testing on board should also include the systems' security capabilities. See [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[5.4.2\]](#).

4.3 Vessel asset inventory

See [Sec.4 \[4.1.2\]](#).

4.4 Physical access controls

See [Sec.4 \[4.1.3\]](#).

4.5 Systems with negligible risk

See [Sec.4 \[4.1.4\]](#).

4.6 Network segmentation

See [Sec.4 \[4.1.5\]](#).

4.7 Security zone boundaries

See [Sec.4 \[4.1.6\]](#).

4.8 Mobile and portable devices

See [Sec.4 \[4.1.7\]](#).

SECTION 6 OPERATION

1 Introduction

Requirements for cyber security in the operation phase are specified in:

- DNV-RU-SHIP Pt.7 Ch.4 Sec.5 [2]: rules for periodical survey of the class notation **Cyber secure**.
- DNV-RU-SHIP Pt.8 Ch.2 Sec.2: rules for the in-operation notation **CSMS** (cyber security management system), including initial survey of the in-operation notation **CSMS**.
- DNV-RU-SHIP Pt.7 Ch.5 Sec.2 [2]: rules for annual survey of the in-operation notation **CSMS**

Within three months after the vessel has been delivered, the shipowner should request approval of the cyber security management system (CSMS) and submit the CSMS documentation.

After the CSMS documents have been approved and within the first annual survey, the shipowner should request a CSMS initial survey.

When the CSMS documentation is approved and the initial survey of the CSMS is completed, the vessel will be assigned in-operation notation **CSMS**.

[2] intends to provide guidance on the required processes of the CSMS.

2 Guidelines for content of CSMS

2.1 General

To protect a ship against cyber security threats, both technical, procedural and people-related measures are needed. The overall intention with the CSMS is to describe and perform the procedural and people related measures.

Valid standards and frameworks for such management systems exist e.g. ISO/IEC 27001 and the *NIST Cybersecurity Framework*. The overall guideline for describing a CSMS is to follow such standards and frameworks, and make sure the systems in scope for the class notation **Cyber secure** are covered. [2.2] to [2.15] give guidelines for the processes required by the in-operation class notation **CSMS**.

2.2 Scope

The information, systems, and vessel services protected by the technical and organizational security barriers should be identified. Personnel and organizations expected to follow policies and procedures in the CSMS should also be identified. The intention is to ensure that relevant stakeholders understand and agree on the boundaries of the CSMS.

- IEC 62443-2-1 section 6.2.1 ORG 1.1: Information security management system (ISMS)
- ISO/IEC 27001 section 4.3: Determining the scope of the information management security management system
- IACS UR E26 chapter 1.3: Scope of applicability.

2.3 Policies and procedures

The activities related to cyber security should be governed by policies and procedures. Note that security policies define overall principles needed to specify configuration of technical security capabilities in the system under consideration (SuC).

See further guidance in the following references:

- ISO/IEC 27001 section 5.2
- ISO/IEC 27001 section 6.2
- ISO/IEC 27001 Annex A, table A.1, item 5.1

- ISO/IEC 27001 Annex A, table A.1, item 5.37
- ISM Code section 2
- IACS UR E26 chapter 5.3

2.4 Risk management

The risk management process should include the activities illustrated in [Figure 1](#).

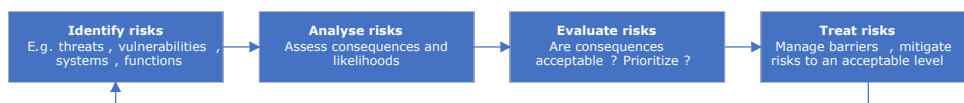


Figure 1 Risk management process

Identification of threats and vulnerabilities requires that a detailed inventory of the systems in the SuC is kept up to date and that security-related configuration is maintained and documented. E.g. hardware devices and operating systems, software applications and versions, firewall settings. This inventory information is then evaluated based on updated threat and vulnerability information, typically provided by subscribing to advisory/alert services by manufacturers and other specialized organizations providing cyber security alerts, warnings, and response services.

The identified risks should be analysed to determine potential consequences and a realistic likelihood of occurrence. See e.g. the 'ease of access method' described in [DNV-RP-0496](#).

Evaluation of the risks entails comparing the consequences with established acceptance criteria and setting priorities for risk treatment. The risks may entail different consequences for confidentiality, integrity and availability and there may be different acceptance criteria for these properties.

Treatment of risks implies management of technical and/or organizational barriers in accordance with the determined consequences and priorities. This means risks may be treated by applying barriers at different levels in the defence-in-depth model (e.g. policies/procedures, zones/conduits, or system security functions). Risk treatment may also entail implementing preventive barriers and/or responsive barriers. In principle, there are four options for risk treatment as follows:

- 1) reduce likelihood and/or consequence of risk
- 2) omit the risk
- 3) transfer the risk
- 4) accept the risk.

Examples of risk treatment may be e.g. installing security patches, updating antivirus signature files, or initiating security awareness training for personnel.

See further guidance in the following references:

- [DNV-RP-0496](#)
- IEC 62443-2-1 section 6.3.1
- ISO/IEC 27001 section 6.1.2
- ISO/IEC 27001 section 6.1.3
- ISO/IEC 27001 section 8.2
- ISO/IEC 27001 section 9.1
- ISO/IEC 27001 section 10.2
- ISO/IEC 27001 Annex A, table A.1, item 8.8
- IACS UR E26 chapter 3.1
- IACS UR E26 chapter 3.2
- IACS UR E26 chapter 4.1.1
- IACS UR E26 chapter 5.3

- IACS UR E26 chapter 6.

2.5 Roles and responsibilities

Responsibilities for security-related activities should be defined and documented. Examples of security-related activities are:

- grant physical access to locations on board
- communicate security awareness information
- conduct security-related training and drills
- manage accounts, authorizations and password policies
- manage changes to hardware and software
- update software/patches
- update malware protection
- perform backup/restore
- respond to incidents.

See further guidance in the following references:

- IEC 62443-2-1 section 6.2.3, ORG 1.3
- ISO/IEC 27001 section 5.3
- ISO/IEC 27001 Annex A, table A.1, item 5.2
- ISM Code section 6
- IACS UR E26 chapter 4.2.4
- IACS UR E26 chapter 4.2.6.

2.6 Personnel security

The policies should include expectations, responsibilities, and describe the disciplinary process in case the policies are breached. Visiting personnel such as contractors, suppliers, and passengers should be included as appropriate. Examples of aspects to be addressed are:

- management of IT-equipment brought on board by crew, passengers, suppliers, etc.
- access to confidential information
- use of email
- use of web services
- private use of corporate devices
- responsibilities related to reporting of theft, illegal disclosure of information, or other breaches of policy
- contractual obligations of employees after termination of employment.

See further guidance in the following references:

- IEC 62443-2-1: section 6.2.2
- ISO/IEC 27001 Annex A, table A.1, item 8.32
- ISO/IEC 27001 Annex A, table A.1, item 5.10
- ISO/IEC 27001 Annex A, table A.1, item 5.19
- IACS UR E26 chapter 4.2.4.

2.7 Management change

Management of change (MOC) processes should be established and enforced for all systems in the SuC. It is expected that modifications are carried out by the respective suppliers, and that the responsibility of adhering to the respective MOC procedures lies with the shipowner.

See further guidance in the following references:

- [DNV-RU-SHIP Pt.4 Ch.9 Sec.1 \[1.6\]](#): Software and hardware change handling
- [DNV-RU-SHIP Pt.7 Ch.1 Sec.2 \[1.5\]](#)
- ISO/IEC 27001 Annex A, table A.1, item 8.32
- ISM Code section 10
- IACS UR E26 chapter 4.1.1.

2.8 Security zones and network segregation

The principles for zones, conduits, and network segmentation should be described in a policy. Examples that should be addressed are:

- segmentation of the different zones (logical, physical, air-gap). E.g. IT, OT, bridge, safety systems, wireless systems
- segmentation of system within the zones (if applicable). E.g. redundant systems, systems by different manufacturers
- boundary protection principles, usage, and type of firewalls. E.g. packet filtering, stateful inspection, proxy/application level
- firewall, software firewall.

See further guidance in the following references:

- [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[3.2\]](#)
- [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 \[4.6\]](#)
- [DNV-RU-SHIP Pt.4 Ch.9 Sec.4 \[3\]](#)
- IEC 62443-2-1: section 8: SPE 3
- IEC 62443-3-3 SR 5.1
- IEC 62443-3-3 SR 5.2
- IEC 62443-3-3 SR 5.4
- ISO/IEC 27001 Annex A, table A.1, item 8.22
- IACS UR E26 chapter 4.2.1.

2.9 Malware protection

The policies and procedures governing maintenance and activities to protect against malware and unauthorized software should consider the inherent security controls of the computer-based systems (e.g. anti-virus software, whitelisting software), procedures by suppliers for updating software, and additional countermeasures established on board (e.g for use of mobile, portable devices).

See further guidance in the following references:

- IEC 62443-2-1 section 9.3.2
- IEC 62443-3-3 SR 3.2
- ISO/IEC 27001 Annex A, table A.1, item 8.7
- IACS UR E26 chapter 4.2.3.

2.10 Access control

The access control policies should provide a basis for configuration of required technical security capabilities related to identification, authentication and use control, and should cover at least the following:

- human user access (management of accounts, identifiers, authenticators, and privileges)
- access by software processes and wireless devices
- access from other zones and from untrusted networks, including remote connections and export of data.

See further guidance in the following references:

- IEC 62443-2-1 section 11.2

- IEC 62443-2-1 section 11.3
- IEC 62443-3-3 FR 1
- IEC 62443-3-3 FR 2
- ISO/IEC 27001
- IACS UR E26 chapter 4.2.4.

2.11 Remote access

The policies and procedures governing access from networks outside of the SuC (untrusted networks) consider the inherent security controls of the computer-based systems (e.g. multifactor authentication, system use notification), procedures by suppliers for remote support, and additional countermeasures established on board (e.g. responsible personnel, explicit access request approval).

See further guidance in the following references:

- [DNV-RU-SHIP Pt.4 Ch.9 Sec.1 \[1.6.6\]](#)
- IEC 62443-3-3 SR 1.1 RE2
- IEC 62443-3-3 SR 1.11
- IEC 62443-3-3 SR 1.12
- IEC 62443-3-3 SR 1.13
- IEC 62443-3-3 SR 1.13 RE1
- IEC 62443-3-3 SR 2.6
- IACS UR E26 chapter 4.2.6.

2.12 Mobile and portable devices

The policies and procedures governing the secure use of mobile, portable, and removable devices should consider the inherent security controls of the computer-based systems (e.g. group policy objects in MS Windows), procedures by suppliers for service and software updates, and additional countermeasures established on board (e.g. procedures for retrieving data from systems in the SuC).

See further guidance in the following references:

- IEC 62443-2-1 section 9.2
- ISO/IEC 27001
- IEC 62443-3-3 SR 2.3
- IACS UR E26 chapter 4.2.7.

2.13 Network operation monitoring

The policies and procedures governing activities for detection of anomalies should include e.g.:

- logging of security events
- audit of security event records
- detection of failed security controls/barriers
- detection of attempted, failed, or successful security breaches.

See further guidance in the following references:

- IEC 62443-2-1 section 12
- IEC 62443-3-3 SR 3.
- IEC 62443-3-3 SR 2.8
- ISO/IEC 27001 Annex A, table A.1, item 5.25
- IACS UR E26 chapter 4.3.1.

2.14 Verification of security functions

The policies and procedures governing activities to ensure correct operation of the security controls should consider the inherent security controls of the computer-based systems (e.g, any automatic mechanisms for reporting security posture), procedures by suppliers (e.g. whether such verification demands credentials only known to the supplier).

See further guidance in the following references:

- IEC 62443-3-3 SR 3.3
- IACS UR E26 chapter 4.3.2.

2.15 Incident response and recovery

An incident response and recovery plan may be summarized as follows:

- 1) create a policy which includes:
 - the purpose, objectives and scope
 - policy owner and review cycle
 - definition of security incident
 - description of security incidents and categories
 - description of incident reporting
 - high-level overview or visualization of incident management process flow
 - definition of roles, responsibilities, and decision-making authority.
- 2) create a plan describing detailed activities, procedures and other necessary information:
 - planning and preparation (event categorization, escalation procedures, logging of incident handling, procedures for testing, contact information)
 - detection and reporting (collecting information related to the event)
 - response (procedures to reduce consequences of the incident, recover from the event and carry out forensics)
 - lessons learned (reviewing and improving security barriers and incident response plans)
- 3) create an incident response team, including establishing relationship with other organizations (CERTs, regulatory authorities, police, etc.)
- 4) create incident training and awareness
- 5) exercise and monitor the incident response capabilities.

See further guidance in the following references:

- IEC 62443-2-1 section 12
- IEC 62443-3-3 SR 7.3
- IEC 62443-3-3 SR 7.4
- ISO/IEC 27001 Annex A, table A.1, item 5.24
- ISO/IEC 27001 Annex A, table A.1, item 5.25
- ISO/IEC 27001 Annex A, table A.1, item 5.26
- ISO/IEC 27001 Annex A, table A.1, item 5.27
- ISO/IEC 27001 Annex A, table A.1, item 5.28
- ISO/IEC 27035-1 Information technology - Information security incident management - Part 1
- ISO/IEC 27035-1 Information technology - Information security incident management - Part 2
- ISM Code section 8
- ISM Code section 9
- IACS UR E26 chapter 4.4
- IACS UR E26 chapter 4.5.

APPENDIX A LIST OF COMPUTER-BASED SYSTEMS IN THE DEFAULT SuC

1 Introduction

1.1 General

This appendix provides guidance on which computer-based systems are part of the default SuC, if installed on board.

In general, these computer-based systems have been found to serve the vessel functions specified in IACS UR E26 chapter 1.3.2 (system in scope), see also [DNV-RU-SHIP Pt.6 Ch.5 Sec.21 Table 9](#).

Other systems, not listed in this appendix may be required to be part of SuC if needed for the operation of the listed vessel functions.

1.2 Control, monitoring, and/or alarm system

Table 1 Control, monitoring, and/or alarm systems

<i>Vessel function</i>	<i>Control, monitoring, alarm system for:</i>
Vessel propulsion	Propulsion
	Propulsion electric power unit
	Propulsion engine
	Propulsion engine speed
	Propulsion engine gas valve unit (GVU)
	Propulsion gas turbine
	Propulsion steam turbine
	Propeller, controllable pitch
	Propulsion thruster electric power unit
	Propulsion thruster engine
	Propulsion thruster engine speed
	Propulsion thruster engine gas valve unit (GVU)
	Propulsion thruster gas turbine
	Propulsion thruster steam turbine
	Propulsion pod, azimuth
	Propulsion pod, fixed
	Propulsion retractable azimuth thruster
	Propulsion retractable fixed thruster
	Propulsion thruster, azimuth
	Propulsion thruster, cycloidal

<i>Vessel function</i>	<i>Control, monitoring, alarm system for:</i>
	Propulsion thruster, fixed
	Propulsion thruster, pump jet
	Propulsion waterjet, fixed
	Propulsion waterjet, variable
	Propulsion thruster controllable pitch propeller hydraulic power system
	Propulsion thruster steering gear electric power system
	Propulsion boiler, oil/gas fired
	Propulsion steam
Steering	Steering
	Steering gear hydraulic power system
	Heading
	Track control
Watertight integrity	Shell doors
	Shell doors water leakage detection alarm
	Internal watertight doors
	Water ingress alarm
Bilge	Bilge water
Ballast	Ballasting
Loading computer	Loading computer
Anchoring and mooring	Anchoring
Auxiliary services	Fuel oil
	Lubricating oil
	Low flashpoint liquid fuel
	Sea water
	Fresh water
	Starting air
	Control air
Other	Main alarm system
	Engineer's alarm system
	Extension alarm and watch responsibility system
	Integrated control and monitoring system

1.3 Electrical systems

Table 2 Electrical systems

<i>Vessel function</i>	<i>Control, monitoring, alarm system for:</i>
Electrical power generation and distribution	Main generator engine
	Main generator engine gas valve unit (GVU)
	Main generator engine speed
	Main generator gas turbine
	Main generator steam turbine
	Main fuel cell power installation
	Main battery systems
	Main battery chargers
	Main switchboard
	Main distribution switchboards
	Main power semi-conductor assemblies
	Main electric power - motor control centres
	Main electric power - motor starters
	Main electric power control and monitoring system
Lighting	Main, emergency, and low-location lighting

1.4 Fire safety systems

Table 3 Fire safety systems

<i>Vessel function</i>	<i>Control, monitoring, and alarm system for:</i>
Fire safety	Firewater
	Machinery spaces fixed gas/foam/water fire extinguishing
	Machinery spaces fixed local application water spraying fire extinguishing
	Fuel cell installation spaces fixed gas/foam/water fire extinguishing system
	Machinery space tank top and bilge fixed gas/foam/water fire extinguishing
	Accommodation fixed water spraying fire extinguishing
	Cargo holds fixed gas/foam/water fire extinguishing
	Cargo deck fixed gas/foam/water fire extinguishing
	Cargo handling spaces fixed gas/foam/water fire extinguishing
	Vehicle, special category and ro-ro spaces fixed gas/foam/water fire extinguishing

<i>Vessel function</i>	<i>Control, monitoring, and alarm system for:</i>
	Regasification plant fixed gas/foam/water fire extinguishing
	Fire detection

1.5 Other safety systems

Table 4 Other safety systems

<i>Vessel function</i>	<i>Safety system for:</i>
Safety functions	Propulsion engine
	Propulsion thruster engine
	Main generator engine
	Main fuel cell power installation
	Fuel gas
	Low flashpoint liquid fuel
	Inert gas control and monitoring system
	Emergency shut down (ESD)
	Boiler safety
	Hydrocarbon gas detection and alarm, fixed
	Hydrogen gas detection and alarm, fixed
	Hydrogen sulphide gas detection and alarm, fixed
	Toxic gases detection and alarm, fixed
	Cargo tanks overflow protection

1.6 Navigational systems and equipment

Table 5 Navigational systems and equipment

<i>Vessel function</i>	<i>System or equipment</i>
Navigation	Integrated navigation system
	Heading control system
	Track control system
	Depth control system
	Loran-C systems
	Differential global positioning systems (DGPS)
	Glonass systems

<i>Vessel function</i>	<i>System or equipment</i>
	Galileo systems
	BeiDou systems
	Gyro compass
	Transmitting header device (THD)
	Heading repeater
	Bearing repeater
	Emergency steering heading indication
	Rate of turn indication
	Speed and distance through water log
	Echo sounder
	Electronic chart display and information systems (ECDIS)
	Voyage data recorder
	Long range identification and tracking (LRIT)
	Navigation light control
	Central alert management (CAM)
	Bridge navigational watch alarm system (BNWAS)
	Radar
	ECDIS
	Automatic identification system (AIS)
	Ground avoidance system
	Sonar system

1.7 Internal communication systems

Table 6 Internal communication systems

<i>Vessel function</i>	<i>System or equipment</i>
Internal communication	Automatic telephone system
	Talk-back system
	Ultra high frequency (UHF) telephone system
	Public address system
	General alarm system

1.8 External communication systems

Table 7 External communication system

<i>Vessel function</i>	<i>System or equipment</i>
External communication	GMDSS - VHF/DSC
	GMDSS - MF/DSC
	GMDSS - MF/HF/DSC/telex
	GMDSS - recognized mobile satellite service
	GMDSS - distress panel
	GMDSS safety information reception - Navtex
	GMDSS safety information reception - EGC
	GMDSS safety information reception - MSI

CHANGES – HISTORIC

August 2021 edition

Changes August 2021

<i>Topic</i>	<i>Reference</i>	<i>Description</i>
Rebranding to DNV	All	This document has been revised due to the rebranding of DNV GL to DNV. The following have been updated: the company name, material and certificate designations, and references to other documents in the DNV portfolio. Some of the documents referred to may not yet have been rebranded. If so, please see the relevant DNV GL document. No technical content has been changed.

October 2020 edition

This is a new document.

About DNV

DNV is the independent expert in risk management and assurance, operating in more than 100 countries. Through its broad experience and deep expertise DNV advances safety and sustainable performance, sets industry benchmarks, and inspires and invents solutions.

Whether assessing a new ship design, optimizing the performance of a wind farm, analyzing sensor data from a gas pipeline or certifying a food company's supply chain, DNV enables its customers and their stakeholders to make critical decisions with confidence.

Driven by its purpose, to safeguard life, property, and the environment, DNV helps tackle the challenges and global transformations facing its customers and the world today and is a trusted voice for many of the world's most successful and forward-thinking companies.

WHEN TRUST MATTERS